

Third-Party Risk Assessment Framework

Version 1.1

August 8, 2026

Prepared By: Brandon Schuerenberg

Framework Alignment: NIST CSF 2.0 / HIPAA Security Rule

PURPOSE

This document establishes a standardized methodology for evaluating third-party vendor risk prior to onboarding and throughout the vendor lifecycle. It applies to all external parties that access, process, store, or transmit Load Tracking Solutions (LTS) data, including but not limited to ELD providers, fuel card services, maintenance platforms, freight brokers, factoring companies, and cloud service providers.

SCOPE

This assessment covers four risk domains: data security, regulatory compliance, operational resilience, and contractual protections. Each domain contains specific evaluation criteria mapped to NIST CSF 2.0 and HIPAA Security Rule requirements where applicable.

APPLICABILITY

All vendors classified as Medium or High criticality must complete this assessment before contract execution. Low-criticality vendors complete a simplified self-assessment questionnaire. Criticality classification is determined by data access level, integration depth, and business dependency.

VENDOR CRITICALITY CLASSIFICATION

Before conducting a full risk assessment, classify each vendor into one of three tiers based on data access, system integration, and business impact.

HIGH CRITICALITY

Criteria: Direct access to customer PII or PHI; real-time API integration with LTS production systems; single point of failure for core operations; handles financial transactions or payment data.

Examples: ELD provider with driver PII access, primary freight broker API integration, factoring company handling invoice payments, cloud hosting provider.

Assessment Required: Full Third-Party Risk Assessment (this document), annual reassessment, continuous monitoring.

MEDIUM CRITICALITY

Criteria: Access to business-confidential data but no PII/PHI; batch or non-real-time integration; viable alternatives exist within 30 days; supports important but non-core functions.

Examples: Fuel card provider, maintenance scheduling platform, secondary broker, compliance software vendor, insurance provider.

Assessment Required: Full Third-Party Risk Assessment (this document), biennial reassessment.

LOW CRITICALITY

Criteria: No access to LTS data or systems; purely transactional relationship; immediate replacement possible; no regulatory implications.

Examples: Office supply vendor, janitorial service, equipment rental (no telematics), marketing agency with no system access.

Assessment Required: Simplified self-assessment questionnaire only. Reassess upon contract renewal.

CLASSIFICATION AUTHORITY

The Compliance Lead assigns criticality tier at vendor intake. Disputes are escalated to program management. Tier assignments are documented in the vendor registry and reviewed annually.

RISK ASSESSMENT DOMAINS

Each vendor is evaluated across four domains. Score each criterion as Satisfactory, Partial, or Unsatisfactory. Document evidence and findings for every criterion.

DOMAIN 1: DATA SECURITY

Mapped to NIST CSF 2.0 PR.DS, PR.AC, PR.PT and HIPAA Section 164.312

1.1 Does the vendor maintain a written information security program?

Evidence Required: Current WISP or security policy document.

Standard: Program addresses access control, encryption, incident response, and employee training. Updated within last 12 months.

1.2 How does the vendor authenticate users accessing LTS data?

Evidence Required: Authentication policy or SOC 2 Type II report Section CC6.

Standard: Unique user credentials enforced. MFA required for privileged access and remote access. Shared accounts prohibited.

1.3 Is LTS data encrypted at rest and in transit?

Evidence Required: Encryption policy or technical documentation.

Standard: AES-256 or equivalent at rest. TLS 1.2+ in transit. Key management procedures documented.

1.4 Does the vendor conduct background checks on employees with access to LTS data?

Evidence Required: HR policy summary (not individual records).

Standard: Criminal, employment, and identity verification completed pre-hire. Periodic re-screening for high-access roles.

1.5 How does the vendor manage and monitor third-party sub-processors?

Evidence Required: Sub-processor list and oversight procedures.

Standard: All sub-processors identified. Written agreements in place. Vendor monitors sub-processor compliance. LTS notified of sub-processor changes with 30-day advance notice.

DOMAIN 2: REGULATORY COMPLIANCE

Mapped to NIST CSF 2.0 GV.OC and HIPAA Section 164.308

2.1 Does the vendor hold relevant security certifications?

Evidence Required: Current SOC 2 Type II, ISO 27001, or HITRUST certificate.

Standard: Certification current and unqualified. Scope includes services provided to LTS.

2.2 Has the vendor experienced a data breach or regulatory action in the past 3 years?

Evidence Required: Written disclosure statement.

Standard: Full disclosure of incidents. Root cause analysis completed. Remediation verified. No unresolved regulatory actions.

2.3 Does the vendor comply with applicable privacy regulations?

Evidence Required: Privacy policy and data processing agreement.

Standard: Compliant with state privacy laws and HIPAA where applicable. Data subject rights processes documented. Breach notification timeline contractually defined.

DOMAIN 3: OPERATIONAL RESILIENCE

Mapped to NIST CSF 2.0 ID.BE, CP

3.1 Does the vendor maintain a business continuity and disaster recovery plan?

Evidence Required: BCDR plan executive summary or test results summary.

Standard: Plan tested within last 12 months. RTO and RPO defined and compatible with LTS requirements.

Alternate processing capability documented.

3.2 What are the vendor's SLA commitments for availability and support?

Evidence Required: Current SLA document or contract exhibit.

Standard: Uptime commitment meets or exceeds LTS requirement (99.5% minimum for High-criticality vendors). Escalation procedures defined. Penalty credits specified.

3.3 Does the vendor carry adequate cyber liability insurance?

Evidence Required: Certificate of insurance.

Standard: Minimum \$2M coverage for High-criticality vendors, \$1M for Medium. LTS named as additional insured. Coverage includes data breach response and regulatory defense.

DOMAIN 4: CONTRACTUAL PROTECTIONS

Mapped to NIST CSF 2.0 GV.PO, ID.RA

4.1 Does the contract include right-to-audit provisions?

Evidence Required: Contract clause reference.

Standard: LTS may audit vendor controls annually or upon security incident. Audit scope and notice period defined.

4.2 Are data ownership and return/destruction obligations defined?

Evidence Required: Contract clause reference.

Standard: LTS retains ownership of all data. Vendor returns or certifies destruction of data within 30 days of contract termination.

4.3 Are breach notification requirements contractually specified?

Evidence Required: Contract clause reference.

Standard: Vendor notifies LTS within 24 hours of confirmed breach. Notification includes scope, affected data, and remediation status. Cooperation obligation defined.

4.4 Are subcontracting and data location restrictions defined?

Evidence Required: Contract clause reference.

Standard: Vendor cannot engage sub-processors without LTS written approval. Data residency requirements specified if applicable. Offshore processing prohibited unless explicitly approved.

SCORING AND DECISION MATRIX

After evaluating all criteria, assign an overall risk rating using the matrix below.

OVERALL RISK RATING CALCULATION

High Criticality Vendor:

- Any Unsatisfactory in Domain 1 or Domain 2 = HIGH RISK
- Two or more Partial ratings across all domains = MEDIUM RISK
- All Satisfactory or one Partial = LOW RISK

Medium Criticality Vendor:

- Any Unsatisfactory in Domain 1 = HIGH RISK
- Any Unsatisfactory in Domains 2-4 OR three or more Partial ratings = MEDIUM RISK
- All Satisfactory or up to two Partial ratings = LOW RISK

DECISION MATRIX

LOW RISK: Approve for onboarding. Standard contract terms apply. Schedule periodic reassessment per criticality tier.

MEDIUM RISK: Conditional approval. Require remediation plan with defined timeline before onboarding. Enhanced monitoring during first 90 days. Contract must include specific security addenda addressing identified gaps.

HIGH RISK: Do not onboard until deficiencies are remediated and re-assessed. If business necessity requires engagement despite HIGH rating, obtain written risk acceptance from program management with documented compensating controls. Reassess within 90 days.

ESCALATION PATH

Disagreements between assessor and vendor regarding findings are escalated to the Compliance Lead. Disagreements regarding risk acceptance are escalated to program management. All escalations and resolutions are documented in the vendor risk file.

DOCUMENT RETENTION

Completed assessments, supporting evidence, and decision records are retained for the duration of the vendor relationship plus three years. Assessments containing PII or PHI are stored in encrypted repositories with access restricted to authorized compliance personnel.